

IDS-IPS SURICATA EN KALI Y DEBIAN

INTRODUCCION

1. **Diseñar y montar** una topología de red aislada en VirtualBox con dos VMs (atacante y víctima) preparadas para tráfico bidireccional sin afectar al host ni a la red corporativa.
2. **Instalar, configurar y validar** Suricata como sistema **IDS** sobre Debian, partiendo de un sistema limpio.
3. **Escribir reglas personalizadas** (firmas) para detectar varios vectores: escaneo, *flood*, fuerza bruta, exfiltración y tráfico malicioso conocido.
4. **Actualizar y gestionar rulesets** profesionales con suricata-update y la fuente *Emerging Threats Open*.
5. **Lanzar ataques controlados** desde Kali (nmap , hping3 , hydra , slowloris , curl con *useragents* sospechosos) y correlacionarlos con las alertas generadas.
6. **Analizar fast.log y eve.json** usando jq para construir métricas (top atacantes, top reglas, líneas de tiempo).
7. **Convertir Suricata en modo IPS** mediante NFQUEUE + nftables para que **bloquee activamente** ataques en línea.
8. **Verificar el comportamiento** end-to-end con tcpdump y Wireshark.
9. **Documentar** los hallazgos en un informe técnico con evidencias.

SERVICIO OBJETIVO EN DEBIAN

Para que los ataques tengan superficie real, instala servicios típicos:

```
sudo apt update  
sudo apt install -y apache2 openssh-server vsftpd curl tcpdump
```

Página de prueba

```
echo "<h1>Servidor de laboratorio</h1>" | sudo tee /var/www/html/index.html
```

Habilitar servicios

```
sudo systemctl enable --now apache2 ssh vsftpd
```

Verificar que escuchan

```
ss -tlnp
```

```
debian@debian:~$ ss -tlnp
State      Recv-Q    Send-Q    Local Address:Port
LISTEN     0          128       0.0.0.0:22
LISTEN     0          128       127.0.0.1:631
LISTEN     0          32        *:21
LISTEN     0          128       [::]:22
LISTEN     0          511       *:80
LISTEN     0          4096      *:3306
LISTEN     0          128       [::1]:631
```

Salida esperada: puertos 21 (FTP), 22 (SSH), 80 (HTTP) abiertos.

INSTALACION DE SURICATA

REPOSITORIO OFICIAL DE OISF

```
sudo apt install -y software-properties-common
sudo add-apt-repository -y ppa:oisf/suricata-stable 2>/dev/null || true
```

```
# Para Debian (sin PPA), usar el repo backports oficial:
echo "deb http://deb.debian.org/debian bookworm-backports main" | \
sudo tee /etc/apt/sources.list.d/backports.list
sudo apt update
sudo apt -t bookworm-backports install -y suricata jq
```

Verificar instalación

```
debian@debian:~$ suricata --build-info | head -30
This is Suricata version 7.0.10 RELEASE
```

CONFIGURAR RED

Ponemos las dos máquinas en Red interna y modo promiscuo para que Suricata vea el tráfico:

Red

Adaptador 1 Adaptador 2 Adaptador 3 Adaptador 4

☒ Habilitar adaptador de red

Conectar a: Red interna

Nombre: intnet

Tipo de Adaptador: Intel PRO/1000 MT Desktop (82540EM)

Promiscuous Mode: Permitir todo

Dirección MAC: 080027D165C7

☒ Virtual Cable Connected

ASIGNAR IPS ESTÁTICAS

En debian (etc/network/interfaces):

```
debian@debian: ~
File Edit View Search Terminal Help
GNU nano 7.2 /etc/network/interfaces *
auto enp0s3
iface enp0s3 inet static
address 192.168.56.10
netmask 255.255.255.0
```

Aplicamos los cambios:

```
debian@debian:~$ sudo ifup enp0s3
debian@debian:~$ ip a show enp0s3
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d1:65:c7 brd ff:ff:ff:ff:ff:ff
    inet 192.168.18.44/24 brd 192.168.18.255 scope global dynamic noprefixroute enp0s3
        valid_lft 2574sec preferred_lft 2574sec
    inet 192.168.56.10/24 brd 192.168.56.255 scope global enp0s3
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fed1:65c7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

En Kali lo mismo, cambiamos la ip, actualizamos y comprobamos:

```
(kali㉿kali)-[~]
└─$ sudo nmcli connection add type ethernet con-name labnet ifname eth0 \
    ipv4.method manual ipv4.addresses 192.168.56.20/24
[sudo] password for kali:
Connection 'labnet' (e1cf567e-58a3-4bf8-8b51-46bfaa6fa958) successfully added
.

(kali㉿kali)-[~]
└─$ sudo nmcli connection up labnet
Connection successfully activated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/4)

(kali㉿kali)-[~]
└─$ ip a show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.20/24 brd 192.168.56.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::550a:459f:3665:c789/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

VERIFICAR CONECTIVIDAD

```
(kali㉿kali)-[~]
└─$ ping -c 3 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data:
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=1.14 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=0.609 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=0.727 ms

— 192.168.56.10 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2013ms
rtt min/avg/max/mdev = 0.609/0.825/1.140/0.227 ms

debian@debian:~$ ping -c 3 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data:
64 bytes from 192.168.56.20: icmp_seq=1 ttl=64 time=0.701 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=64 time=0.377 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=64 time=0.670 ms

--- 192.168.56.20 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2054ms
rtt min/avg/max/mdev = 0.377/0.582/0.701/0.145 ms
```

Verificar conectividad mediante ssh:

```
(kali㉿kali)-[~]
$ ssh debian@192.168.56.10
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established
.
ED25519 key fingerprint is: SHA256:iAxw0j+u/Yzqeq791E10P1KCwlQAryzM4QsKMKaXPF
C
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hos
ts.
debian@192.168.56.10's password:
Linux debian 6.1.0-53-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.187-1 (2026-09-
07) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
debian@debian:~$
```

CONFIGURAR SURICATA

MODIFICAR YAML

DEFINIR REDES

Sudo nano /etc/suricata/suricata.yaml.

En selección vars, esto se hace para distinguir el tráfico interno de externo. Si no habría falsos positivos:

```
vars:
  # more specific is better for alert accuracy and performance
  address-groups:
    #HOME_NET: "[192.168.0.0/16,10.0.0.0/8,172.16.0.0/12]"
    HOME_NET: "[192.168.56.0/24]"
    EXTERNAL_NET: '$HOME_NET'
    HTTP_SERVERS: '$HOME_NET'
    SSH_SERVERS: '$HOME_NET'
    DNS_SERVERS: '$HOME_NET'
    #HOME_NET: "[10.0.0.0/8]"
    #HOME_NET: "[172.16.0.0/12]"
    #HOME_NET: "any"
```

CONFIGURAR LA INTERFAZ DE CAPTURA

En af-packet:

interface: enp0s8 (la que te toque)

cluster-id: 99

cluster-type: cluster_flow

defrag: yes

use-mmap: yes

tpacket-v3: yes

```

cluster-type: cluster_flow
# In some fragmentation case
# to yes, the kernel will do
defrag: yes
# To use the ring feature of
use-mmap: yes
# Lock memory map to avoid i
# subscribing could lock you
#mmap-locked: yes
# Use tpacket_v3 capture mod
# Don't use it in IPS or TAF
tpacket-v3: yes
af-packet:
- interface: enp0s3
# Number of receive
#threads: auto
# Default cluster id
cluster-id: 99

```

HABILITAR EVE.JSON

Confirmar que en outputs está activo:

```

outputs:
- eve-log:
  enabled: yes
  filetype: regular
  filename: eve.json
  types:
    - alert:
      payload: yes
      payload-printable: yes
      packet: yes
      metadata: yes
      http-body: yes
    - http:
    - dns:
    - tls:
    - flow:
    - ssh:
    - stats:
      threads: yes

```

```

types:
- alert:
  payload: yes
  # payload-buffer-size: 4
  payload-printable: yes
  packet: yes
  metadata: yes
  http-body: yes

```

ACTIVAR EL ARCHIVO DE REGLAS EN EL YAML

```
rule-files:
- suricata.rules
- /etc/suricata/rules/local.rules
```

VALIDAR CONFIGURACION

El warning es por no tener reglas, las configuramos despues:

```
debian@debian:~$ sudo suricata -T -c /etc/suricata/suricata.yaml -v
Info: conf-yaml-loader: Configuration node 'EXTERNAL_NET' redefined.
Info: conf-yaml-loader: Configuration node 'HTTP_SERVERS' redefined.
Info: conf-yaml-loader: Configuration node 'DNS_SERVERS' redefined.
Notice: suricata: This is Suricata version 7.0.10 RELEASE running in SYSTEM mode
Info: cpu: CPUs/cores online: 2
Info: suricata: Running suricata under test mode
Info: suricata: Setting engine mode to IDS mode by default
Info: exception-policy: master exception-policy set to: auto
Info: logopenfile: fast output device (regular) initialized: fast.log
Info: logopenfile: eve-log output device (regular) initialized: eve.json
Info: logopenfile: stats output device (regular) initialized: stats.log
Warning: detect: No rule files match the pattern /var/lib/suricata/rules/suricata.rules
```

ARCHIVO DE REGLAS LOCALES PARTE 1

REGLAS DE RECONOCIMIENTO

Sudo nano /etc/suricata/rules/local.rules

Puedes probar primero con “alert icmp any any -> any any (msg:"Petición ICMP detectada"; sid:1000001; rev:1;)” que sirve para ver cualquier petición.

```
# =====
# REGLAS LOCALES DE LABORATORIO — Suricata 7.x
# Convención SID: 100xxx para reglas didácticas locales
# =====
```

```
# --- 1. Reconocimiento -----
```

```
# nmap SYN scan (-sS): muchos SYN sin establecer conexión, desde mismo origen puedes modificar el
threshold, alomejor 30 y 60 es demasiado alto.
```

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Nmap SYN scan detectado"; \
flags:S; threshold:type both, track by_src, count 30, seconds 60; \
classtype:attempted-recon; sid:100100; rev:1;)
```

```
# nmap NULL scan: ninguna flag activa (anómalo)
```

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Nmap NULL scan detectado"; \
flags:0; classtype:attempted-recon; sid:100101; rev:1;)
```

```
# nmap FIN scan: solo FIN, sin sesión previa
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Nmap FIN scan detectado"; \
flags:F; flow:stateless; classtype:attempted-recon; sid:100102; rev:1;)
```

```
# nmap XMAS scan: FIN + PSF + URG
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Nmap XMAS scan detectado"; \
flags:FPU; classtype:attempted-recon; sid:100103; rev:1;)
```

VALIDAR REGLAS

```
debian@debian:~$ sudo suricata -T -c /etc/suricata/suricata.yaml -S /etc/suricata/rules/local.rules
Info: conf-yaml-loader: Configuration node 'EXTERNAL_NET' redefined.
Info: conf-yaml-loader: Configuration node 'HTTP_SERVERS' redefined.
Info: conf-yaml-loader: Configuration node 'DNS_SERVERS' redefined.
i: suricata: This is Suricata version 7.0.10 RELEASE running in SYSTEM mode
i: suricata: Configuration provided was successfully loaded. Exiting.
```

ACTUALIZAMOS EL RULESET

Habilita la fuente Emerging Threats Open:

```
debian@debian:~$ sudo suricata-update enable-source et/open
22/9/2026 -- 09:13:53 - <Info> -- Using data-directory /var/lib/suricata.
22/9/2026 -- 09:13:53 - <Info> -- Using Suricata configuration /etc/suricata/suricata.yaml
22/9/2026 -- 09:13:53 - <Info> -- Using /etc/suricata/rules for Suricata provided rules.
22/9/2026 -- 09:13:53 - <Info> -- Found Suricata version 7.0.10 at /usr/bin/suricata.
22/9/2026 -- 09:13:53 - <Warning> -- Source index does not exist, will use bundled one.
22/9/2026 -- 09:13:53 - <Warning> -- Please run suricata-update update-sources.
22/9/2026 -- 09:13:53 - <Info> -- Creating directory /var/lib/suricata/update/sources
22/9/2026 -- 09:13:53 - <Info> -- Source et/open enabled
debian@debian:~$ sudo suricata-update list-sources --enabled
22/9/2026 -- 09:14:16 - <Info> -- Using data-directory /var/lib/suricata.
22/9/2026 -- 09:14:16 - <Info> -- Using Suricata configuration /etc/suricata/suricata.yaml
22/9/2026 -- 09:14:16 - <Info> -- Using /etc/suricata/rules for Suricata provided rules.
22/9/2026 -- 09:14:16 - <Info> -- Found Suricata version 7.0.10 at /usr/bin/suricata.
Enabled sources:
- et/open
```

Descargamos y compilamos las reglas con “sudo suricata-update” y verificamos el archivo generado:

```
debian@debian:~$ ls -lh /var/lib/suricata/rules/suricata.rules
-rw-r--r-- 1 root root 79K Sep 22 09:15 /var/lib/suricata/rules/suricata.rules
```

PONER EN MARCHA SURICATA

Hacemos un restart “sudo tail -f /var/log/suricata/fast.log” y nos ponemos a la escucha:

```
debian@debian:~$ sudo tail -f /var/log/suricata/fast.log
```

LANZAR ATAQUES DESDE KALI PARTE 1

RECONOCIMIENTO NMAP

SYN Scan completo (top 100 puertos):

```
(kali㉿kali)-[~]  
$ sudo nmap -sS -T4 192.168.56.10  
09/22/2026-11:00:44.256062  [**] [1:100100:1] LAB Nmap SYN scan detectado [**] [Classification: Attempted Information Leak]  
[Priority: 2] {TCP} 192.168.56.20:33393 -> 192.168.56.10:23
```

Null scan:

```
(kali㉿kali)-[~]  
$ sudo nmap -sN -T4 192.168.56.10  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 11:03 -0400  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.56.10  
Host is up (0.00054s latency).  
Not shown: 996 closed tcp ports (reset)  
PORT      STATE      SERVICE  
21/tcp    open|filtered ftp  
22/tcp    open|filtered ssh  
80/tcp    open|filtered http  
3306/tcp  open|filtered mysql  
MAC Address: 08:00:27:D1:65:C7 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.32 seconds  
09/22/2026-11:03:23.490178  [**] [1:100101:1] LAB Nmap NULL scan detectado [**] [Classification: Attempted Information Leak]  
[Priority: 2] {TCP} 192.168.56.20:58063 -> 192.168.56.10:1034  
09/22/2026-11:03:23.491053  [**] [1:100101:1] LAB Nmap NULL scan detectado [**] [Classification: Attempted Information Leak]  
[Priority: 2] {TCP} 192.168.56.20:58063 -> 192.168.56.10:109
```

FIN scan:

```
(kali㉿kali)-[~]  
$ sudo nmap -sF -T4 192.168.56.10  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 11:04 -0400  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.56.10  
Host is up (0.00044s latency).  
Not shown: 996 closed tcp ports (reset)  
PORT      STATE      SERVICE  
21/tcp    open|filtered ftp  
22/tcp    open|filtered ssh  
80/tcp    open|filtered http  
3306/tcp  open|filtered mysql  
MAC Address: 08:00:27:D1:65:C7 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds  
[Priority: 2] {TCP} 192.168.56.20:54846 -> 192.168.56.10:32770  
09/22/2026-11:04:50.501865  [**] [1:100102:1] LAB Nmap FIN scan detectado [**] [Classification: Attempted Information Leak]  
[Priority: 2] {TCP} 192.168.56.20:54846 -> 192.168.56.10:10628  
09/22/2026-11:04:50.502166  [**] [1:100102:1] LAB Nmap FIN scan detectado [**] [Classification: Attempted Information Leak]  
[Priority: 2] {TCP} 192.168.56.20:54846 -> 192.168.56.10:32772
```

XMAS scan:

```
(kali@kali)-[~]
$ sudo nmap -sX -T4 192.168.56.10

Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 11:07 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.10
Host is up (0.00045s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE      SERVICE
21/tcp    open|filtered ftp
22/tcp    open|filtered ssh
80/tcp    open|filtered http
3306/tcp  open|filtered mysql
MAC Address: 08:00:27:D1:65:C7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.54 seconds

09/22/2026-11:07:27.969499  [**] [1:100103:1] LAB Nmap XMAS scan detectado [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.56.20:35691 -> 192.168.56.10:1108
09/22/2026-11:07:27.970127  [**] [1:100103:1] LAB Nmap XMAS scan detectado [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.56.20:35691 -> 192.168.56.10:6669
```

REGLAS Y ATAQUES PARTE 2

REGLAS DE DENEGACION DE SERVICIO

--- 2. Denegación de servicio (flood) -----

SYN flood

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Posible SYN flood"; \
flags:S; threshold:type both, track by_src, count 200, seconds 5; \
classtype:attempted-dos; sid:100200; rev:1;)
```

ICMP flood

```
alert icmp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Posible ICMP flood"; \
itype:8; threshold:type both, track by_src, count 100, seconds 5; \
classtype:attempted-dos; sid:100201; rev:1;)
```

UDP flood

```
alert udp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Posible UDP flood"; \
threshold:type both, track by_src, count 200, seconds 5; \
classtype:attempted-dos; sid:100202; rev:1;)
```

ATAQUES FLOOD

SYN flood:

```
(kali㉿kali)-[~]
$ sudo hping3 -S -p 80 --flood 192.168.56.10
[sudo] password for kali:
HPING 192.168.56.10 (eth0 192.168.56.10): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 192.168.56.10 hping statistic —
119505 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

09/22/2026-12:38:12.436094  [**] [1:2210008:2] SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 192.168.56.20:54824 -> 192.168.56.10:80
09/22/2026-12:38:12.436096  [**] [1:2210008:2] SURICATA STREAM 3way handshake SYN resend different seq on SYN rcv [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 192.168.56.20:54826 -> 192.168.56.10:80
09/22/2026-12:38:12.436107  [**] [1:2210004:2] SURICATA STREAM 3way handshake SYNACK resend with different ack [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 192.168.56.10:80 -> 192.168.56.20:54824
```

ICMP flood:

```
(kali㉿kali)-[~]
$ sudo hping3 --icmp --flood 192.168.56.10
HPING 192.168.56.10 (eth0 192.168.56.10): icmp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 192.168.56.10 hping statistic —
822 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

09/22/2026-12:40:45.864160  [**] [1:100201:1] LAB Possible ICMP flood [**] [Classification: Attempted Denial of Service] [Priority: 2] {ICMP} 192.168.56.20:8 -> 192.168.56.10:0
```

UDP flood:

```
(kali㉿kali)-[~]
$ sudo hping3 --udp -p 53 --flood 192.168.56.10
HPING 192.168.56.10 (eth0 192.168.56.10): udp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 192.168.56.10 hping statistic —
6274 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

09/22/2026-12:41:56.452960  [**] [1:100202:1] LAB Possible UDP flood [**] [Classification: Attempted Denial of Service] [Priority: 2] {UDP} 192.168.56.20:2361 -> 192.168.56.10:53
```

REGLAS Y ATAQUES PARTE 3

REGLAS DE FUERZA BRUTA

--- 3. Fuerza bruta -----

SSH brute force: muchos intentos de conexión al 22

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 22 (msg:"LAB Posible fuerza bruta SSH"; \
flow:to_server,established; threshold:type both, track by_src, \
count 10, seconds 60; classtype:attempted-user; sid:100300; rev:1;)
```

FTP brute force

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 21 (msg:"LAB Posible fuerza bruta FTP"; \
content:"USER"; nocase; threshold:type both, track by_src, count 10, \
seconds 60; classtype:attempted-user; sid:100301; rev:1;)
```

ATAQUES DE FUERZA BRUTA

SSH, crea un diccionario primero y luego ataca:

```
(kali@kali)-[~]
$ cat > /tmp/passwords.txt <<'EOF'
123456
password
admin
root
toor
qwerty
letmein
1234
EOF

(kali@kali)-[~]
$ hydra -l student -P /tmp/passwords.txt ssh://192.168.56.10 -t 4 -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-22 12:
49:41
[DATA] max 4 tasks per 1 server, overall 4 tasks, 8 login tries (l:1/p:8), ~2
tries per task
[DATA] attacking ssh://192.168.56.10:22/
[ATTEMPT] target 192.168.56.10 - login "student" - pass "123456" - 1 of 8 [ch
ild 0] (0/0)
[ATTEMPT] target 192.168.56.10 - login "student" - pass "password" - 2 of 8 [
child 1] (0/0)
[ATTEMPT] target 192.168.56.10 - login "student" - pass "admin" - 3 of 8 [chi
ld 2] (0/0)
[ATTEMPT] target 192.168.56.10 - login "student" - pass "root" - 4 of 8 [chil
d 3] (0/0)
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume ses
sion.

09/22/2026-12:49:41.968463  [**] [1:2001219:20] ET SCAN Potential SSH Scan [**] [Classification: Attempted Information Leak]
[Priority: 2] {TCP} 192.168.56.20:45092 -> 192.168.56.10:22
09/22/2026-12:49:41.968463  [**] [1:2003068:7] ET SCAN Potential SSH Scan OUTBOUND [**] [Classification: Attempted Informat
ion Leak] [Priority: 2] {TCP} 192.168.56.20:45092 -> 192.168.56.10:22
09/22/2026-12:49:42.060041  [**] [1:2006546:9] ET SCAN LibSSH Based Frequent SSH Connections Likely BruteForce Attack [**]
[Classification: Attempted Administrator Privilege Gain] [Priority: 1] {TCP} 192.168.56.20:45084 -> 192.168.56.10:22
```

REGLAS Y ATAQUES PARTE 4

REGLAS DE HTTP Y PAYLOADS

--- 4. HTTP / Web ataques -----

User-Agent de Nikto (escáner web)

```
alert http $EXTERNAL_NET any -> $HTTP_SERVERS any (msg:"LAB Nikto User-Agent detectado"; \
flow:to_server,established; http.user_agent; content:"Nikto"; nocase; \
classtype:web-application-attack; sid:100400; rev:1;)
```

User-Agent de sqlmap

```
alert http $EXTERNAL_NET any -> $HTTP_SERVERS any (msg:"LAB sqlmap User-Agent detectado"; \
flow:to_server,established; http.user_agent; content:"sqlmap"; nocase; \
classtype:web-application-attack; sid:100401; rev:1;)
```

Intento de SQLi básico en URI

```
alert http $EXTERNAL_NET any -> $HTTP_SERVERS any (msg:"LAB SQLi en URI: UNION SELECT"; \
flow:to_server,established; http.uri; content:"UNION"; nocase; \
content:"SELECT"; nocase; distance:0; within:30; \
classtype:web-application-attack; sid:100402; rev:1;)
```

Directory traversal

```
alert http $EXTERNAL_NET any -> $HTTP_SERVERS any (msg:"LAB Directory traversal en URI"; \
flow:to_server,established; http.uri; content:"../"; \
classtype:web-application-attack; sid:100403; rev:1;)
```

--- Detección de payloads concretos -----

Cadena 'malicious_payload' como prueba de detección por contenido

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB Payload de prueba detectado"; \
content:"malicious_payload"; nocase; classtype:bad-unknown; sid:100600; rev:1;)
```

ATAQUES DE HTTP Y PAYLOADS

Escaner web – Nikto

```
(kali@kali)-[~]
$ nikto -h http://192.168.56.10
- Nikto v2.6.1

+ Target IP:      192.168.56.10
+ Target Hostname: 192.168.56.10
+ Target Port:    80
+ Platform:      Linux/Unix
+ Start Time:     2026-09-22 12:56:23 (GMT-4)

09/22/2026-12:56:30.148093  [**] [1:100403:1] LAB Directory traversal en URI [**] [Classification: Web Application Attack]
[Priority: 1] {TCP} 192.168.56.20:37274 -> 192.168.56.10:80
09/22/2026-12:56:30.148093  [**] [1:2049401:1] ET WEB_SERVER /etc/hosts Detected in URI [**] [Classification: Attempted Inf
ormation Leak] [Priority: 2] {TCP} 192.168.56.20:37274 -> 192.168.56.10:80
09/22/2026-12:56:30.149503  [**] [1:100403:1] LAB Directory traversal en URI [**] [Classification: Web Application Attack]
```

Payload de prueba:

```
(kali㉿kali)-[~]
└─$ echo "malicious_payload" | nc 192.168.56.10 80
HTTP/1.1 400 Bad Request
Date: Tue, 22 Sep 2026 17:03:36 GMT
Server: Apache/2.4.68 (Debian)
Content-Length: 345
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at debian.debian Port 80</address>
</body></html>

09/22/2026-13:03:44.731274  [**] [1:100600:1] LAB Payload de prueba detectado [**] [Classification: Potentially Bad Traffic]
[Priority: 2] {TCP} 192.168.56.20:35878 -> 192.168.56.10:80
```

ANALISIS FORENSE DE LOGS

VISTA HUMANA

sudo tail -F /var/log/suricata/fast.log

```
debian@debian:~$ sudo tail -F /var/log/suricata/fast.log
[sudo] password for debian:
09/22/2026-13:02:49.493695  [**] [1:100100:1] LAB Nmap SYN scan detectado [**] [Classification: Attempted Information Leak]
[Priority: 2] {TCP} 192.168.56.20:42500 -> 192.168.56.10:80
09/22/2026-13:02:49.495453  [**] [1:2221010:1] SURICATA HTTP unable to match response to request [**] [Classification: Gene
ric Protocol Command Decode] [Priority: 3] {TCP} 192.168.56.10:80 -> 192.168.56.20:42500
09/22/2026-13:03:32.365172  [**] [1:100100:1] LAB Nmap SYN scan detectado [**] [Classification: Attempted Information Leak]
[Priority: 2] {TCP} 192.168.56.20:57758 -> 192.168.56.10:80
```

CONTAR ALERTAS POR SID

sudo jq -r 'select(.event_type=="alert") | .alert.signature_id' \
/var/log/suricata/eve.json | sort | uniq -c | sort -rn

```
debian@debian:~$ sudo jq -r 'select(.event_type=="alert") | .alert.signature_id' \
/var/log/suricata/eve.json | sort | uniq -c | sort -rn
1485 2210008
1403 2210004
1004 100103
1004 100102
1004 100101
131 2009714
53 100403
46 2049401
32 2027264
32 2027262
18 100100
9 2101245
7 2260002
6 2027250
6 2016141
6 2010766
5 2010939
5 2010937
5 2010936
5 2010935
5 100402
4 2221010
4 2101402
4 2101244
4 100600
4 100200
```

TOP 10 ATACANTES

```
sudo jq -r 'select(.event_type=="alert") | .src_ip' \  
/var/log/suricata/eve.json | sort | uniq -c | sort -rn | head
```

```
debian@debian:~$ sudo jq -r 'select(.event_type=="alert") | .src_ip' \  
/var/log/suricata/eve.json | sort | uniq -c | sort -rn | head  
4925 192.168.56.20
```

CRONOLOGIA DE UN ATAQUE (POR SID)

```
sudo jq -r 'select(.event_type=="alert" and .alert.signature_id==100200)  
| "\(.timestamp) \(.src_ip) -> \(.dest_ip):\(.dest_port)"' \  
/var/log/suricata/eve.json
```

```
debian@debian:~$ sudo jq -r 'select(.event_type=="alert" and .alert.signature_id==100200)  
| "\(.timestamp) \(.src_ip) -> \(.dest_ip):\(.dest_port)"' \  
/var/log/suricata/eve.json  
2026-09-22T12:38:10.790229-0400 192.168.56.20 -> 192.168.56.10:80  
2026-09-22T12:55:25.151589-0400 192.168.56.20 -> 192.168.56.10:80  
2026-09-22T12:56:25.670122-0400 192.168.56.20 -> 192.168.56.10:80  
2026-09-22T12:56:30.160271-0400 192.168.56.20 -> 192.168.56.10:80
```

ALERTAS POR SEVERIDAD

```
sudo jq -r 'select(.event_type=="alert") | .alert.severity' \  
/var/log/suricata/eve.json | sort | uniq -c
```

```
debian@debian:~$ sudo jq -r 'select(.event_type=="alert") | .alert.severity' \  
/var/log/suricata/eve.json | sort | uniq -c  
208 1  
3219 2  
2905 3
```

VER PAYLOAD COMPLETO

```
sudo jq 'select(.alert.signature_id==100600)' /var/log/suricata/eve.json
```

```
debian@debian:~$ sudo jq 'select(.alert.signature_id==100600)' /var/log/suricata/eve.json  
{  
  "timestamp": "2026-09-22T13:03:44.731274-0400",  
  "flow_id": 194082946692314,  
  "in_iface": "enp0s3",  
  "event_type": "alert",  
  "src_ip": "192.168.56.20",  
  "src_port": 35878,  
  "dest_ip": "192.168.56.10",  
  "dest_port": 80,  
  "proto": "TCP",  
  "pkt_src": "stream (flow timeout)",  
  "metadata": {  
    "flowints": {  
      "http.anomaly.count": 1
```

MODO IPS CON NFQUEUE

Hasta aquí Suricata **detecta** (IDS). Ahora lo convertiremos en **prevención** (IPS): rechazará paquetes en línea.

CAMBIAR REGLAS ALERT -> DROP

Creamos /etc/suricata/rules/drop.rules

```
debian@debian: ~  
File Edit View Search Terminal Help  
GNU nano 7.2 /etc/suricata/rules/drop.rules  
# Bloquear SYN flood en línea  
drop tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"IPS DROP SYN flood"; \  
flags:S; threshold:type both, track by_src, count 200, seconds 5; \  
sid:200200; rev:1;)  
# Bloquear ICMP flood  
drop icmp $EXTERNAL_NET any -> $HOME_NET any (msg:"IPS DROP ICMP flood"; \  
threshold:type both, track by_src, count 100, seconds 5; \  
sid:200201; rev:1;)  
# Bloquear nmap NULL scan en cuanto se ve un solo paquete  
drop tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"IPS DROP NULL scan"; \  
flags:0; sid:200101; rev:1;)
```

Y las añadimos al yml

```
rule-files:  
- suricata.rules  
- /etc/suricata/rules/local.rules  
- /etc/suricata/rules/drop.rules
```

REDIRIGIR EL TRAFICO A NFQUEUE CON NFTABLES

```
sudo apt install -y nftables
```

```
sudo nft add table inet filter
```

```
sudo nft add chain inet filter forward { type filter hook forward priority 0 \; }
```

```
sudo nft add chain inet filter input { type filter hook input priority 0 \; }
```

```
# Enviar todo el tráfico entrante de la red de laboratorio a la cola 0
```

```
sudo nft add rule inet filter input iif "enp0s8" queue num 0 bypass
```

```
debian@debian:~$ sudo nft add table inet filter  
sudo nft add chain inet filter forward { type filter hook forward priority 0 \; }  
sudo nft add chain inet filter input { type filter hook input priority 0 \; }  
debian@debian:~$ sudo nft add rule inet filter input iif "enp0s8" queue num 0 bypass
```

El parámetro bypass evita que el tráfico se pierda si Suricata cae — política de *fail-open*. Para producción crítica se usa fail-closed.

ARRANCAR SURICATA EN MODO IPS

Detén el servicio normal y lanza en modo NFQ:

```
debian@debian:~$ sudo systemctl stop suricata
sudo suricata -c /etc/suricata/suricata.yaml -q 0 -D
i: suricata: This is Suricata version 7.0.10 RELEASE running in SYSTEM mode
```

-q 0 indica leer de la cola NFQUEUE 0.

-D corre en background.

VERIFICAR EL BLOQUEO

Desde Kali, repite el SYN flood:

```
(kali㉿kali)-[~]
└─$ sudo hping3 -S -p 80 --flood 192.168.56.10
HPING 192.168.56.10 (eth0 192.168.56.10): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 192.168.56.10 hping statistic —
35986 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

debian@debian:~$ sudo tail -F /var/log/suricata/fast.log | grep DROP
09/22/2026-14:06:50.453519 [Drop] [**] [1:200200:1] IPS DROP SYN flood [**] [Classification: (null)] [Priority: 3] {TCP} 1
92.168.56.20:1369 -> 192.168.56.10:80
09/22/2026-14:06:55.520661 [Drop] [**] [1:200200:1] IPS DROP SYN flood [**] [Classification: (null)] [Priority: 3] {TCP} 1
92.168.56.20:36436 -> 192.168.56.10:80
```

DASHBOARD CON EVEBOX

Para visualizar gráficamente las alertas:

```
debian@debian:~$ echo "deb https://evebox.org/files/debian stable main" | \
sudo tee /etc/apt/sources.list.d/evebox.list
curl -fsSL https://evebox.org/files/GPG-KEY-evebox | sudo apt-key add -
sudo apt update
sudo apt install -y evebox
deb https://evebox.org/files/debian stable main

debian@debian:~$ sudo evebox oneshot /var/log/suricata/eve.json
```

The screenshot shows the EveBox dashboard in a web browser. The browser window has a title bar that says "debian (antes de modificar el yaml de suricata) [Corriendo] - Oracle VirtualBox". The browser's address bar shows the URL "http://127.0.0.1:5636/#/events". The dashboard has a navigation bar with links to "EveBox", "Inbox", "Escalated", "Alerts", "Stats", "Events", and "Dashboards". There is a "Help" button and a notification icon with "0". Below the navigation bar, there are several statistics cards: "86,379 ALL EVENTS", "6,342 ALERT", "19 ANOMALY", "3 DHCP", "1,446 FILE INFO", "75,938 FLOW", "1,533 HTTP", "5 SSH", and "1,093 STATS". There is a "Refresh" button and a dropdown menu for "Event Type" set to "All". A search bar is also present. Below these are buttons for "Newest", "Newer", "Older", and "Oldest". The main content area is a table with the following columns: "Timestamp", "Type", "Src/Dst", and "Description". The table contains 9 rows of data, all with "STATS" as the type and "Packets=36448 Bytes=1460222 Uptime: 20 minutes" as the description. The timestamps range from "2026-09-22 14:11:11" to "2026-09-22 14:10:15". The browser's status bar at the bottom shows the address bar with "EveBox — Mozilla Fir..." and a taskbar with various icons.

Timestamp	Type	Src/Dst	Description
2026-09-22 14:11:11 a minute ago	STATS		Packets=36448 Bytes=1460222 Uptime: 20 minutes
2026-09-22 14:11:03 a minute ago	STATS		Packets=36448 Bytes=1460222 Uptime: 20 minutes
2026-09-22 14:10:55 2 minutes ago	STATS		Packets=36448 Bytes=1460222 Uptime: 20 minutes
2026-09-22 14:10:47 2 minutes ago	STATS		Packets=36448 Bytes=1460222 Uptime: 20 minutes
2026-09-22 14:10:39 2 minutes ago	STATS		Packets=36448 Bytes=1460222 Uptime: 20 minutes
2026-09-22 14:10:31 2 minutes ago	STATS		Packets=36448 Bytes=1460222 Uptime: 20 minutes
2026-09-22 14:10:23 2 minutes ago	STATS		Packets=36448 Bytes=1460222 Uptime: 19 minutes
2026-09-22 14:10:15 2 minutes ago	STATS		Packets=36448 Bytes=1460222 Uptime: 19 minutes